

Eilo Project Management Plan

Version 2.0

5 October 2026

Project owner Lasung Sherpa

Eilo is a free, local-first voice companion for English-speaking adults. This plan governs delivery from setup through release and monitoring. It incorporates the approved blue/lavender ripple design, optional visual responses, confirmed live-search scope and platform-specific outside-app presentation. It retains encrypted device-local memory and a minimal Neon account database.

The project is ready for task-scoped engineering setup, not production release. Native conversation performance, background availability, secure locked-memory writes, authentication and revised visual surfaces still require evidence. The owner reviews each small task before progression. Staging, backend deployment, store submission and public release have separate decisions.

Document authority follows the current decision register, requirements JSON1.5 and Design 2.0. Earlier prototypes and approval statements are historical where superseded. Financial allowances, schedule and team capacity in this plan are planning assumptions and confer no spending authority.

Document control

Field	Current record
Change	CR-2026-10-05-01 visual design and scope merge
Product	Eilo pronounced AY-lo
Tagline	I am here for you
Backlog	175 tasks across 23 feature groups
Design	Version 2.0 requirements and semantic tokens
Implementation	Application development not started
Verification	Earlier synthetic prototype checks only; new native tests not run
Approval	Prior UX review approved 2 October; current merge requested 5 October
Next decision	Review assumptions, then authorize one setup task

Contents

- 1 Project initiation and strategy
- 2 Stakeholders and kickoff
- 3 App store and platform strategy
- 4 Product requirements
- 5 UI and UX design system
- 6 Architecture and data boundaries
- 7 API and event contracts
- 8 Budget and resource assumptions
- 9 Timeline and work breakdown
- 10 Risk management plan
- 11 Communication and reporting
- 12 Sprint planning and resource tracking
- 13 Data mapping matrix
- 14 Consent and encryption architecture
- 15 Regulatory and privacy assessment
- 16 CI and CD pipeline
- 17 Change requests and issue management
- 18 Monitoring and quality assurance
- 19 Beta distribution tracker
- 20 Store submission and release assets
- 21 Post launch observability
- 22 Closeout and continuous improvement
- 23 Template coverage and deliverable status
- 24 Assumption register and next task
- 25 Official references

1 Project initiation and strategy

Business case

We intend to provide casual spoken conversation without routine cloud inference bills or required typing. Local inference reduces exposure of conversations to service providers and can keep the core experience usable offline. Local memory supports continuity without a cloud history service. Optional visual text makes spoken replies easier to follow; permitted source results add value when an explicitly confirmed search is needed.

This remains a product hypothesis. The existence of compact models does not demonstrate usefulness, device compatibility or willingness to install large model packs. Validate these with a small adult pilot before scaling. Track comprehension of listening/privacy controls, successful conversational turns and user-reported usefulness through voluntary structured studies, not content telemetry.

The core app remains free with no introduced daily conversation quota. Funding is assumed to be founder-supported for the initial pilot. Advertising, sale of personal data and subscriptions are not approved. Sponsorship, grants or optional paid additions are future business decisions and cannot degrade free core conversation. Live search introduces variable costs; it requires a funded provider envelope and honest availability fallback. No commitment to free unlimited third-party search is made.

Project charter

Element	Charter provision
Objective	Demonstrate useful offline voice conversation, protected local continuity and a clear visual experience on both platforms
Sponsor and product authority	Lasung Sherpa as project owner; role assumption
Delivery authority	Coding agent executes only individually authorized tasks; owner controls scope, spending and release
Scope	Local audio/inference/memory, optional account access, revised visual controls and staged confirmed search
Exclusions	Calls/camera/contact control, GPS, cloud history, training uploads, children, medical treatment and unlimited assistant privileges
Planning horizon	18 working weeks after equipment/toolchain readiness, subject to feasibility and re-estimation
Financial authority	No approved budget commitment; illustrative allowance appears in section 8
Success	Required privacy and device acceptance evidence, useful pilot results and explicit release sign-off
Stop condition	Unresolved privacy failure, unsupported background promise, unaffordable provider design or unacceptable conversation quality

Charter acceptance record: owner decision, date, scope and financial ceiling must be entered before funded execution. Approval of this document does not automatically authorize all 175 tasks.

2 Stakeholders and kickoff

Stakeholder register

Role or party	Interest and influence	Responsibility
Project owner	High decision influence	Product priorities, task acceptance, budget and release
Coding agent	High delivery influence	Small diffs, focused verification, evidence and progress records
Adult pilot participants	High usability relevance	Voluntary task feedback and consent comprehension
Native mobile specialist	High technical influence when engaged	Lifecycle, audio, signing and platform constraints
Independent security reviewer	High release influence when engaged	Key/storage composition, races, provider boundaries
Privacy or legal adviser	High jurisdiction influence when engaged	Entity coverage, notices, contracts and release assessment
Apple and Google	High distribution influence	Store review and platform permission policies
Neon and selected auth host	High service dependency	Account availability, security, retention and processing
Search/media provider	High optional-feature dependency	Attribution rights, cost, retention and service limits

Specialist roles are needs, not hired people. The owner initially holds product and project management roles. No partner, vendor contract or participant group is assumed established. The app is a consumer product independent of the owner's community-support employment.

Kickoff meeting agenda

Allow 60 minutes: confirm the product and free-core constraints 10 minutes; examine privacy/data paths 10; review native feasibility and equipment 15; walk the revised design 10; choose the first task and evidence 10; record decisions and owners 5. A solo owner can complete this as a documented review without inventing a meeting or attendees.

Before kickoff, prepare a toolchain/device inventory, requirements/backlog, this plan, design tokens, known limitations and proposed repository owner/name. Outcomes are one task authorization, a resource-gap list, next review timing and recorded unresolved decisions. Do not provision paid services merely to complete an agenda.

Decisions already recorded

Android/iOS and English; local persistent memory; explicit listening/background consent; optional guest/email/social access; Neon PostgreSQL account persistence; Eilo name/tagline; UX approval; GitHub public initially/private later; merged ripple, visual responses and search-result scope. Brand/domain availability remains unchecked. No project repository or live backend has been created in this work.

3 App store and platform strategy

We plan one shared React Native interface with native Kotlin/Swift lifecycle components and in-process C++ inference. Custom native development builds are necessary; Expo Go cannot validate the engine. Pin supported toolchain/dependency versions when the authorized setup task begins.

Surface	Distribution and purpose	Release condition
Android development	Native development build	Reproducible compile and synthetic fixture launch
Android staging	Google Play internal or closed track	Signed approved candidate and testers' consent
iOS development	Native development build	Xcode/signing access and test device provisioning
iOS staging	TestFlight	Signed candidate and any applicable beta review
Public stores	App Store and Google Play	Owner approval, review outcomes and production evidence
Website	Vercel candidate	Privacy/support/account deletion routes validated

Assume an Australia-first adult pilot and English storefront copy. Expansion to other countries requires a fresh jurisdiction and support assessment. Store territory is not proof that residents elsewhere cannot install or process data. Provisional native test baselines are Android15+ and iOS18+, with at least 8 GB RAM for initial model evaluation; these are test hypotheses, not the announced production support list. The final list follows real-device results, current SDK/store requirements and dependency support.

Background audio is an already-running user-started mode, not a system assistant replacement. No availability after force-quit, reboot or process death is promised. Test Android OEM constraints and iOS intended-purpose background policy early. No silent-audio, private API or fake-call workaround is allowed.

Outside-app visual parity is deliberately platform-specific. Android may show a permissioned overlay; iOS uses a generic system notification and may require opening Eilo for rich content. Eligible Live Activities remain a feasibility investigation. Notifications do not grant background microphone permission or guarantee immediate delivery. The app never automatically opens itself to simulate an overlay.

Store submission must truthfully disclose microphone/background purpose, optional query processing, account data and local history. Never claim untested battery, latency, security, always-on operation or device coverage. Store accounts, signing keys and legal publishing identity require owner assignment before release.

4 Product requirements

Core conversation

Explicit Start plus microphone permission enables native wake standby. The wake phrase opens a session, ordinary ambient speech does not. Follow-ups use bounded current context and permitted local memory. ASR, conversational inference and installed offline TTS remain on-device. Interruptions cancel stale generation/audio. Stop releases the microphone. An idle conversation returns to standby after 60 seconds without speech, processing or playback, measured after playback finishes.

History and derived memory require explicit consent and encrypted local storage. Default retention is 90 days, personal storage ceiling 250,000,000 bytes excluding generic models, with an 80% warning. Private sessions write nothing. Source deletion invalidates dependent memory. No cloud restoration, transfer or account-based memory unlock is promised.

Account access

Guest conversation remains equally available. Optional email/password, Google and Apple on iOS use a separately hosted Better Auth service with Neon PostgreSQL. Account access/recovery is separate from authenticated local memory. Exact framework schemas and mobile compatibility are untested. Sign-in never starts capture or restores memory; account outage does not block configured offline use.

New visual and search requirements

VR01-VR10 specify truthful ripple states, accessible theme/motion, progressive spoken-response text, independent visual preferences, result cards, expiry/pinning, media playback, native navigation and transient-data boundaries. SR01-SR06 specify provider review, confirmed minimized queries, ephemeral gateway, untrusted result normalization, safe media and offline/cost fallback. OR01-OR06 specify Android overlay, iOS fallback, consent/lock boundaries and integrated native evidence.

Live search is off initially and confirms each proposed query. No transcript, memory corpus, account ID, raw audio, exact GPS or personal weights enter the request. Display consent alone is insufficient for external data transfer. No query/results/media persistence in Neon or diagnostic logs. Provider processing and IP access remain disclosed external exposure.

Acceptance principle

Every requirement has a primary task and full-app acceptance coverage. A desktop or browser check cannot establish physical-device performance, protected storage or background feasibility. Definitions in JSON1.5 and Design 2.0 govern the exact changed behavior; earlier exclusions of all search and old teal screens are superseded.

5 UI and UX design system

The revised Home uses a blended light-blue/lavender background and centre-out rounded waves while actively listening or speaking. A static Start mark and labelled states distinguish stopped, standby and thinking. One-second looping is an initial motion reference; production comfort and energy use remain test outcomes. Reduce Motion replaces decoration with a static mark. Keep Start/Stop, Home/Memory/Settings and privacy status accessible; minimal appearance cannot remove essential controls.

Spoken-response text appears progressively when no permitted rich result exists. Show only clauses released for speech, excluding hidden draft or cancelled future output. Rich results replace the default card, retain a way back to the spoken answer and identify sources. The earlier sketch's places, ratings and travel times are examples, not factual content to ship.

Control	Specified behavior
Voice only	Suppresses response visuals; retains previous type choices
Text Images Videos	Independent allowed categories; unavailable result types are not fabricated
Default choices	Text on; images/video off as planning assumptions
Keep visible	Pins current card in current unlocked session, not durable saving
Close	Dismisses display without stopping audio/listening
Video play	Explicit tap; pause Eilo speech/listening, expose Resume conversation
Visual expiry	20 seconds idle after speech/loading/interaction/video; separate from 60-second conversation timer
Lock or Stop	Clears personal cards, pending result callbacks and transient caches

Use stable opaque surfaces beneath readable text. Light text colour #172642 and primary #2453C6; dark text #F1F4FF and primary #B8CBFF. Gradient endpoints and all semantic roles are in tokens 2.0. Measure actual composited contrast rather than approving screenshots by appearance. Design targets are 4.5:1 normal text,3:1 essential controls and 48 logical-unit shared hit regions. Native accessibility and scaled layouts require device testing.

Design 2.0 is a specification, not a Figma delivery. Editable semantic tokens and written screen/flow specifications are the current handoff. Exact assets, app icons, native light/dark components and@2x/@3x raster exports remain implementation deliverables. The earlier interactive prototype 1.2 and 22 contrast-pair checks do not validate this revision.

6 Architecture and data boundaries

The native controller owns capture, cancellation, generation IDs, policy epochs, listening state and privacy transitions. React Native presents authorized state; it does not keep the engine alive. Native inference runs in-process. Initial evaluation candidates remain Moonshine Small Streaming ASR, Qwen3-1.7 B Q4_K_M non-thinking via llama.cpp and installed offline English system TTS. Qwen3-0.6 B is a comparison candidate; Kokoro remains deferred. Wake/VAD checkpoint licensing still needs selection.

Component	Responsibility	Boundary
Native audio and inference	Wake, turn detection, recognition, response and speech	No cloud inference or raw-audio storage
Native memory	SQLCipher history/facts, key policy and retention	Personal keys/history never in JS or backend
Native presentation controller	Active display, expiry, pin and privacy epochs	Volatile current-session content
Android surface adapter	Permissioned overlay and service controls	No unrelated app-input capture
iOS surface adapter	Generic system notification; optional eligible ActivityKit	No arbitrary system-assistant panel
Identity service	Auth/profile/lifecycle	Minimal Neon data only
Search gateway	Credentials, validated query, normalized source results	No account/history DB path; no payload logs
Model manager	Manifest, integrity, versioning and rollback	Generic licensed assets, no personal uploads

On lock, cancel sensitive generation/output, invalidate memory and display sessions, close history and clear decrypted buffers. Generic locked conversation may continue only where permitted; earlier memory cannot be read. Consented new history writes use the proposed sealed ciphertext inbox with vetted envelope encryption and protected private-key access. This composition requires review and physical-device validation; a public encryption key is not speaker authentication.

The selected authentication route is a custom Better Auth service backed by Neon rather than assumed Neon-managed native auth support. Vercel Node hosting is recommended subject to lifecycle, region, connection and job requirements. A persistent Node host remains the fallback. Docker is optional for backend development and does not provide the iOS Xcode build environment.

Search and media introduce external query/provider traffic. Core offline conversation retains zero conversation-content egress; the privacy disclosure must describe the separately confirmed query exception without claiming all use is offline.

7 API and event contracts

Contracts below are proposed interfaces. Implement machine-readable OpenAPI and pinned auth-library schemas in their authorized tasks; no endpoint exists yet. All examples use synthetic values. Session identity is derived server-side; a client cannot choose another user's subject.

Interface	Proposed input and output	Security and errors
Auth framework routes	Email/provider credentials; framework session	Pinned generated schema, verification/expiry, nonce/redirect protections
GET /v1/profile	Valid session; optional name and verified account email	401 invalid session; no history fields
PATCH /v1/profile	Optional displayName up to 80 characters	Server-derived owner; validation; no arbitrary fields
DELETE /v1/account	Fresh reauthentication and idempotency key	Revoke sessions promptly; verified deletion state
GET /v1/account/deletion	Protected operation ID	Pending/completed/failed; never false success
POST /v1/search	Confirmed query, allowed media types, random request ID	No account subject; 256-character query and bounded results are assumptions
Search result envelope	Source title/HTTPS URL, bounded snippet, timestamp when available, media/license metadata	Untrusted input; no executable HTML; no fabricated availability
Native DisplayEvent	Session/generation/policy epoch, mode, spoken clause or normalized result	Reject stale epoch; current authorized surface only
Native commands	Start, Stop, SetDisplayMode, DismissCard, PinCard	Existing local authorization and lock gates

Search confirmation is enforced in the client broker before gateway invocation; the gateway must independently validate shape/origins and resource limits. Anonymous access remains available to guests. Abuse protection must not silently introduce a durable identity or conversation-query log. Review attestation/short-lived capabilities and bounded IP/security metadata as needed, with documented purpose and retention. Consent flags alone do not prevent malicious clients or query leakage.

Use bounded query/result sizes, timeouts and cancellation, with sanitized 400/401/403/429/5xx errors. Do not echo raw query/credentials into errors. Auth and search services isolate secrets, permissions and logs even if initially sharing one hosting provider. Search has no database-write credentials. Media fetching allowlists origins, validates redirects/type/size and blocks private networks or unsafe URL schemes.

Mobile and API schemas evolve additively because old mobile binaries remain installed. Breaking changes require versioned contracts and a supported transition. Deletion operations are idempotent; failed/offline remote deletion remains pending while local confirmed deletion is tracked separately.

8 Budget and resource assumptions

No monetary budget has been approved. The following AUD allowances support planning and must be replaced by provider quotes, actual capacity and owner-approved ceilings. They are not current product prices. Search/media usage beyond this prototype allowance requires its own demand/cost model.

Item	Basis	AUD allowance
Engineering opportunity cost	360 founder hours x 80 assumed value	28,800
Physical test equipment	Device access/purchase allowance	1,500
Security and privacy review	Limited specialist review allowance	2,000
Build and CI services	Initial evaluation allowance	600
Store accounts and administration	Allowance, not quoted fees	400
Hosting auth email and search pilot	Initial pilot allowance	300
Participant study	Recruitment/incentive allowance	300
Design and licensed assets	Initial allowance	200
Cash subtotal excluding founder time	Sum of above cash items	5,300
Total before contingency	28,800 + 5,300	34,100
Contingency	20% of total	6,820
Planning economic total	34,100 + 6,820	40,920
Cash envelope with 20% contingency	5,300 x 1.2	6,360

Assume one founder allocating 20 hours/week over 18 working weeks, with agent assistance included within that capacity rather than treated as unlimited independent labor. Capacity and hourly value are illustrative. Do not announce a finish date until early native spikes establish throughput. Security review scope may require more money than the allowance.

For operations, use an initial review threshold of AUD300/month as an assumption, not a spending authorization or proven capacity estimate. Alert at 50% and 80% of an approved actual ceiling; disable new discretionary provider calls at 100% while keeping offline conversation available. Never meter free local conversation to hide a backend overrun. Build frequency, downloads, search calls, media transfer, database/session volumes and email delivery all affect actual cost.

ROI cannot be credibly quantified before funding or revenue is selected. Pilot value is measured by usefulness, repeat interest and privacy comprehension. Record spend incurred and forecast remaining cost weekly; obtain owner approval for commitments. Resource records must show actuals separately from these allowances.

9 Timeline and work breakdown

T0 is the date the owner authorizes setup and confirms equipment, accounts and capacity. Weeks are working-week ranges, not calendar commitments. The schedule assumes 20 hours/week and must be re-estimated after the first two weeks. Do not compress privacy gates to preserve an assumed date.

Milestone	Indicative weeks	Work and exit evidence
M0 setup	1 to 2	Repository/board, toolchain/signing and clean native builds
M1 voice feasibility	3 to 6	Offline audio/ASR/LLM/TTS, interruption, screen-off and thermal evidence
M2 protected continuity	7 to 10	Keys/SQLCipher/sealed inbox, retention/deletion, backup exclusions
M3 foreground product	11 to 13	Revised Home/visual controls, Memory/Settings and account integration
M4 online and outside surfaces	14 to 16	Provider approval, confirmed search, safe media, Android overlay and iOS fallback
M5 pilot and release candidate	17 to 18	Integrated device matrix, security/privacy assessment and pilot decision

M1 and M2 are critical feasibility gates. A failed experiment can be a completed engineering task while its product requirement remains unmet. Report pass/fail/not-tested for each device. If iOS background support or secure locked writes cannot satisfy the specification, request a reviewed scope decision; do not silently ship an unsafe approximation.

The original 149 tasks remain, with 26 additional tasks in VIS, SEARCH, SURFACE and DEVOPS. Existing audio/model/security tasks retain their stable IDs. WBS packages are setup, native speech, memory/security, foreground product, account lifecycle, external content, outside-app surfaces and release verification. The JSON dependency graph governs eligibility; broad milestone ranges do not override it.

One issue equals one coherent, independently testable responsibility. Aim for a reviewable session-sized change; split tasks exceeding roughly one to two working days of active effort, excluding necessary soak tests. Before implementation record scope, acceptance, dependencies, focused test and task approval. No mass feature scaffold is authorized by this plan. Funding and device gaps can shift the entire schedule.

10 Risk management plan

Score likelihood and impact from 1 low to 5 high; product gives the planning priority. Ratings are assumptions to update with evidence. 15+ escalates before affected work continues; privacy failures block release regardless of score.

ID	Risk	L x I	Mitigation and owner
R01	iOS background use unavailable or rejected	4 x 5=20	Native/policy spike before full product; owner and mobile lead
R02	Local model latency quality heat or RAM fails	4 x 5=20	CPU/foreground/screen-off measurements and support list; mobile lead
R03	Locked inbox/key composition exposes history	3 x 5=15	Vetted cryptography, independent review and races; security lead
R04	Results leak on lock notifications or logs	3 x 5=15	Central epoch invalidation, generic notices, cache/traffic audit; security lead
R05	Search provider retains sensitive queries	4 x 4=16	Explicit minimization, confirmation and provider contract gate; owner
R06	Anonymous search abuse creates cost	4 x 4=16	Resource caps, bounded abuse controls and funded feature fallback; backend lead
R07	Mobile auth or Apple redirects fail	3 x 4=12	Early synthetic integration, no account dependency for offline core; backend lead
R08	Model/media license prevents redistribution	3 x 4=12	Exact artifact license inventory before bundling; owner
R09	Public Git history leaks secret or user data	3 x 5=15	Secret scanning, synthetic evidence, trusted CI boundaries; delivery lead
R10	Accessibility or fast motion harms usability	3 x 4=12	Reduce Motion, contrast/text scaling and participant/device tests; design lead
R11	Assumed capacity or budget underestimated	4 x 3=12	Re-estimate after spikes; defer optional search before core privacy; owner
R12	Policy/jurisdiction changes before launch	3 x 4=12	Fresh official-source review before submission; privacy lead

Role leads may initially be the owner with agent support; no hiring is implied. Every risk record adds status, trigger, action due date, evidence and residual score. Review high risks weekly and before related milestones. A risk is closed only with evidence, not because a mitigation was written.

Escalation example: inability to clear video/image caches on lock is a privacy blocker. Pause the affected media surface, preserve working offline conversation and create a scoped fix or design change. No content uploads or weaker lock policy are acceptable unreviewed remedies.

11 Communication and reporting

Event	Audience	Frequency	Required output
Task start	Owner	Each authorized task	Scope, dependencies and intended verification
Task completion	Owner	Each task	Diff, environment, results, limitations and next task
Project health	Owner	Weekly	Scope, risk, actual/forecast cost and milestone evidence
Sprint planning/review	Owner and engaged contributors	Every 2 weeks	Goal/capacity, accepted tasks and retrospective
Critical issue	Owner	Immediately when confirmed	Affected behavior, containment and decision needed
Release decision	Owner	Each candidate	Build/config/evidence and explicit authorization

Do not send email, Slack messages, invitations or participant communications without explicit authorization. Reports are documents/issues until a communication channel is agreed. Use a concise owner-facing summary with links to evidence, not raw conversation logs or real user recordings.

Project status report template

Reporting period; current milestone; accepted tasks this period; tasks waiting for review; failed/not-run gates; top risks and actions; spend actual/forecast versus approved ceiling; schedule forecast and explanation; requested decisions; next authorized task. Each section needs a named owner and source record. Initially report native feasibility as not tested and funded budget as not approved; do not substitute green status.

Decision log

ID	Decision	Status
D01	Free English adult local conversation and local memory	Prior approved product baseline
D02	Optional accounts with Neon identity persistence	Owner authorized direction
D03	UX review of previous design	Approved 2 October 2026
D04	GitHub public initially then private	Owner confirmed
D05	Ripple/results/spoken-text design merged	Owner requested 5 October 2026
D06	Provider, production regions and operational limits	Open release decisions
D07	Timeline, capacity and cash allowances	Planning assumptions pending owner review

Store exact decision text, approver, date and affected requirement/task IDs. Approval of a design is not a physical-device test result; approval of a task is not approval to publish its artifacts externally.

12 Sprint planning and resource tracking

Use two-week planning cycles with one active implementation task. Select only dependency-ready work and reserve capacity for review/fixes. With the assumed 40 hours per cycle, start with 28 planned development hours, 8 verification/review hours and 4 contingency hours. This is an allocation assumption to calibrate, not measured velocity.

Initial sprint planning record

Sprint 01 dates are unset until T0. Goal: establish management controls and reproducible native development builds. Candidate tasks are VC-DEVOPS-01 and VC-DEVOPS-02 plus the appropriate existing BASE setup task after authorization. Later build/signing follows verified native prerequisites. Only the first selected task is active. Native code experiments do not gain blanket approval from sprint planning.

Field	Required value at planning
Sprint and goal	Unique ID and one evidence-based outcome
Capacity	Contributor available hours excluding leave and other commitments
Selected tasks	Stable ID, dependency status and explicit task authorization
Forecast	Small estimate with uncertainty and included verification
Acceptance owner	Person who reviews the result
Carryover	Failed/unreviewed work with reason, not silently marked complete

Timesheet and resource record

Record date, contributor, task ID, category, planned hours, actual hours, remaining estimate and short non-sensitive work note. Categories are implementation, verification, review, research and administration. Founder time records economic cost; invoices and provider bills record cash cost separately. Agent/runtime charges require actual billing evidence, not an assumed hourly equivalence.

Track WIP at one active task, cycle time from authorized start to acceptance, review waiting time and blocked duration. Do not use lines of code or number of tests as productivity scores. Initial estimates are provisional until the first completed cycle. Keep participant research capacity distinct from invented engineering evidence.

Retrospective at cycle end: what helped; what slowed review; one process change; owner and next review date. No fabricated sprint outcomes, attendee names, burndown history or timesheet actuals are populated by this plan.

13 Data mapping matrix

Every data class needs purpose, storage, access, transfer, retention and deletion evidence. The following is the current design map; exact framework/vendor fields require implementation inventory.

Data class	Storage and access	Transfer and lifecycle
Raw microphone buffer	Bounded native RAM only	No upload/file; discard after processing/Stop
User and assistant text	Native RAM; encrypted local history only with consent	No history upload; 90-day default and source-aware deletion
Derived personal memory	Encrypted local store; authenticated unlocked access	No cloud; follows source expiry/deletion
Private-session text	Authorized volatile memory	No persistent rows/caches; clear on privacy transitions
Locked-turn envelopes	Backup-excluded local ciphertext inbox	Protected import after auth; within retention/quota
Keys	Device-only protected facilities/native buffers	Never JS/cloud; clear buffers on lock, reset on delete
Account identity/profile	Auth service and Neon; authenticated owner access	Declared identity purpose; deletion lifecycle
Hashes sessions verification	Auth framework and protected device session	Bounded expiry/cleanup; never raw credentials in logs
Provider account links/tokens	Restricted auth lifecycle store	Minimal scopes, encryption/revocation where supported
Confirmed search query	Temporary client/gateway/provider processing	Provider receives disclosed query/network metadata; no Neon/body log
Search snippets/media/URLs	Session-only authorized display/cache	No durable result history; clear expiry/dismiss/lock/Stop
Visual/preferences consent	Non-content device settings	Local purpose only; does not imply history or search consent
Operational diagnostics	Minimal sanitized error/build/status metadata	No content identifiers; bounded retention to approve
Generic model files	Verified device files/CDN	Licensed generic assets only; provider network logs reviewed

Account deletion and local history deletion are distinct. Sign-out preserves encrypted history unless explicitly erased under device authentication. Different identity switching requires an authenticated local reset. Password/provider recovery does not restore local history. Other devices cannot be remotely wiped; notices must accurately explain this limit.

Proposed active account deletion target is 7 days after verified request, with prompt session revocation. Backups, PITR, branches and provider logs require a finite justified retention schedule before release. A restore must reapply deletion records. No production PII/session copy enters preview Neon branches. Any new data field requires updating this matrix and the privacy notice before implementation.

14 Consent and encryption architecture

Consent matrix

Capability	Default and grant	Revocation or denial
Microphone	Off until Start and native permission	Stop capture, no repeated prompts
Background listening	Off; separate explicit choice	Leaving app stops capture when disabled
Local history	Neither choice preselected at onboarding	No new writes after authenticated policy change
Private session	Explicit local choice	No retroactive saving when ended
Account	Optional with guest skip	Offline core continues on denial/outage
Visual text	Recommended on; local preference	Voice only disables response cards
Images and video	Recommended off	No media loading without permitted type
Live search	Off; each query preview/confirmation	No request on cancel/deny
Android overlay	Off plus special permission	Remove surface; safe voice/notification fallback
iOS notifications	Native permission and user settings	No substitute forced launch
Tracking	No tracking feature planned	No ATT prompt unless actual scope changes

Essential controls and operational state remain visible even in Voice only. Lock does not authorize changing persistent sensitive settings. Consent categories are independent; agreeing to images is not permission for microphone, background use or provider queries.

Encryption matrix

Path	Intended protection	Evidence required
Local history/journals	SQLCipher authenticated native configuration and protected key handling	Exact build review, WAL/temp paths and backup tests
Locked inbox	Vetted authenticated envelope encryption	Standard library/format, nonce/integrity and lock-read denial
Device credentials	Keychain/Keystore policy, non-synchronizing where needed	Actual key access/auth lifecycle and buffer clearing
Account database	Provider encryption at rest and least privilege	Current Neon/auth configuration and contracts
App/service/provider transport	HTTPS, TLS1.3 target, audited TLS1.2 compatibility only if necessary	Endpoint negotiation and trust validation
Signing secrets	Restricted CI secret stores and owner access	Least privilege, rotation/recovery and audit

AES-256 is a target for compatible local storage/envelope encryption, not evidence that every provider uses that exact configuration. Verify password-hash algorithm and work factors from the pinned auth framework. Do not invent custom cryptography or promise forensic deletion. TLS encrypts transport; it does not prevent the provider seeing a search query it processes.

15 Regulatory and privacy assessment

The attached checklist names GDPR and HIPAA controls. Applicability must be assessed rather than marked compliant because encryption exists. Eilo is a general adult conversation product, not a medical service or emergency monitor. Conversations can still contain sensitive disclosures; the design treats local content as sensitive irrespective of marketing category.

Area	Current assessment and required gate
Australian Privacy Act	Assess entity turnover and exceptions, including health-service activity; do not assume a startup exemption
Australian privacy operations	Collection notice, purpose, access/correction, retention, overseas processing and breach response require provider-specific evidence
GDPR	Assess establishment, offering services to people in the Union or monitoring; Australia-first launch does not by itself settle scope
HIPAA	No covered-entity/business-associate relationship identified in current consumer scope; reassess before any healthcare partnership
ATT and advertising	No cross-app tracking or advertising SDK planned; avoid unnecessary prompts, reassess actual data practices
Cookies and website	Use only necessary auth cookies initially; nonessential tracking would require separate review
Store privacy declarations	Account/auth/query/media processing and microphone/background purpose must match real builds
Consumer and AI safety	Honest AI identity, limitations and no misleading treatment or guaranteed safety claims

OAIC guidance identifies small-business exceptions and health-service coverage. HHS ties HIPAA obligations to covered-entity or business-associate status; a casual app is not automatically HIPAA-regulated. GDPR territorial scope is conditional and can apply to free services. These are planning assessments, not legal clearance. Obtain a qualified review for the actual entity, storefronts, contracts and sensitive processing before public release.

Create an incident plan covering detection, containment, credential revocation, evidence preservation without content capture, risk assessment, applicable regulator/user notices and remediation. Reporting deadlines and responsible entity must be determined under the applicable law; do not invent one universal deadline. Practice an account credential breach and an accidental query-log scenario using synthetic records.

Provider review includes subprocessors, hosting regions, cross-border access, logging defaults, data use, retention/deletion, security contracts and costs. Australian database placement alone does not guarantee Australia-only processing. No cloud conversation backup, even encrypted ciphertext, is in this release. Personal model/adaptor uploads remain future research requiring a separate specification.

16 CI and CD pipeline

GitHub is selected, public initially and private later. Use one repository with mobile, account service, optional search gateway, contracts, documentation and CI definitions. Maintain the task/backlog source of truth through stable IDs. Code in an external Git repository need not be duplicated as document storage.

Stage	Trigger and controls	Evidence
Pull request	Authorized task branch; least-privilege Actions	Relevant lint/type/unit/integration and sanitized artifacts
Native checks	Relevant native/toolchain changes	Gradle on suitable runner; iOS on macOS/Xcode
Owner review	Focused PR and task report	Acceptance or changes requested with date
Staging build	Manual authorized batch of accepted tasks	EAS/native build IDs, commit/config/version/signature
Device verification	Restricted signed builds	Physical device/OS/runtime matrix and failures
Production candidate	Approved commit with production config	Tested candidate retained for store promotion where supported
Backend deployment	Separate owner approval	Compatible migration, smoke checks and rollback procedure
Store upload and release	Separate decisions and store review	Submission record, review outcome and rollout authorization

Use EAS Build/Submit for custom React Native native binaries subject to feasibility. It supports existing native projects; source/build services may process proprietary code and must be included in provider review. GitHub Actions plus Gradle/Xcode/fastlane is the fallback when EAS integration or cost does not fit. Docker can reproduce backend tests, not replace macOS signing/toolchains.

Vercel hosts the candidate small account API/website; Neon stores minimal identities. Isolate dev/staging/prod credentials, projects, databases, callback URLs and provider keys. Use synthetic staging accounts; never clone production PII into preview environments. Search is separately permissioned and cannot write to Neon.

GitHub environment required reviewers have plan/repository-visibility restrictions. Before switching private, verify supported enforcement. Owner-controlled manual deployment is a process gate, not independent two-person enforcement. Restrict trusted release workflows/secrets and store publication rights. Pin dependencies/actions by reviewed version or digest. Untrusted PR jobs do not receive production or signing secrets.

Mobile rollout rollback is not instantaneous: older binaries remain installed. Use additive contracts/migrations, staged rollout and corrective releases. Defer OTA updates until a reviewed runtime-compatibility and approval policy exists; native changes require new binaries. A staging-configured build is not automatically identical to a production candidate.

17 Change requests and issue management

Current change record

Field	CR-2026-10-05-01
Requester	Project owner
Request	Finalize and merge standalone ripple, visual results and spoken-text fallback
Accepted scope	Design 2.0 requirements, updated artifacts and 26 new tasks
Product impact	Replaces teal Home; adds optional search and platform-specific surfaces
Privacy impact	Explicit confirmed query/provider processing; history remains local
Delivery impact	Native display, media/overlay, provider/cost review and added acceptance gates
Authorization boundary	Documentation/design merge only; no app implementation/deployment
Financial impact	Unpriced provider demand; allowances remain assumptions

Future changes record ID/date/requester, reason, requirements affected, dependencies, data changes, schedule/cost/risk impact, options, owner decision, implementation task and verification evidence. A bug fix restoring approved behavior does not automatically authorize new data collection or a different privacy promise.

Initial issue register

Issue	State	Next evidence
Native Android/iOS build and device access	Not established	Authorized inventory/setup
Host 10.5 GB versus proposed 16 GB allocation	Deferred by owner	Recheck hardware during development
Qwen conversion/package	Incomplete	Authorized artifact preparation task
Background and sealed inbox feasibility	Not tested	Physical native/security experiments
Search/media provider	Not selected	SR01 contracts/license/cost review
Revised palette and device accessibility	Not tested	VR02 and OR06 evidence
Better Auth native integration	Not tested	Existing AUTH integration tasks
GitHub private gate enforcement	Not configured	DP04 selected-plan assessment

Use issue severity and owner, not risk score alone, to triage defects. Security/privacy exposure is critical; block release and affected surface immediately. Critical functional failure blocks the relevant milestone. Minor cosmetic issues can be scheduled with explicit acceptance. Record technical debt with a reason, review date and consequences; do not silently label a failed requirement as debt.

18 Monitoring and quality assurance

Metrics and thresholds

Measure	Planning target or rule	Actual baseline
Meaningful reply audio	Median 1.5 s and p 95 3 s engineering targets	No physical-device results
Interruption stop	p 95 300 ms target	Not measured
Content egress	Zero transcript/history upload; confirmed query exception only	Native traffic audit not run
Locked disclosure	Zero personal-content exposure	Native race tests not run
Offline guest core	Works after setup with networking blocked	Not tested on phones
Visual expiry	20-second idle semantics and pin/lock overrides	Specified, not implemented
Accessibility	Defined contrast, scaling and screen-reader task success	Revised palette/device tests not run
Crash-free sessions	Proposed 99.5% pilot target using minimal opted-in data	No pilot data
Release defects	No unresolved critical/high privacy/security defects	No production assessment

No measured velocity or burndown exists. For each sprint, plot remaining estimated work by day only after actual records exist. Review accepted tasks, carryover, cycle time and blocked hours alongside scope changes. Story points, if introduced, are team-relative estimates, not hours or comparisons between contributors.

Test layers are deterministic controller/storage/expiry units; native integration; synthetic API/security tests; physical voice/lifecycle/storage/accessibility tests; participant usability; and release candidate regression. Each run records task/requirement IDs, OS/device, model/runtime/toolchain versions, procedure, expected/actual result and evidence location. Safe synthetic marker checks supplement, but do not replace, encryption/cache/backup inspection.

Bug log template

Bug ID, linked requirement/task, build and device, severity, reproducible steps, expected/actual, sanitized evidence, owner, status, fix commit and retest result. Never attach private user recordings or transcripts. Acceptance review checks failed/not-run cases explicitly; a polished demo does not close the quality gate.

Beta promotion requires all essential core/privacy tests passing on the declared support list, remaining limitations disclosed and owner approval. Live search and overlays require their own gates; a provider outage must preserve offline core availability.

19 Beta distribution tracker

Use TestFlight and Google Play internal/closed tracks for restricted testing. First internal testers verify installation and synthetic scenarios. External adult participants receive a clear beta notice, model download requirements, microphone/background controls and limitations. Recruitment, messaging and real-user access require explicit owner authorization.

Tracker field	Required record
Candidate	Version/build number, approved SHA and production/staging config
Artifact	EAS/native build ID and store upload reference
Platform	OS/device support list and signing identity
Cohort	Internal/closed group and authorized access window
Data policy	Synthetic test data or separately consented adult study
Tests	Required acceptance matrix, pass/fail/not-tested
Approval	Owner decision/date and restrictions
Distribution	Uploaded, reviewed, available, expired or withdrawn
Feedback	Sanitized bug links and optional structured study findings

Propose five to ten adult usability participants for the first study and a maximum 25-device restricted beta as planning assumptions. Do not describe these cohorts as recruited. Participants should test Start/Stop, knowing whether Eilo listens, guest setup, local memory loss/deletion, voice/text preferences, search confirmation and pin/expiry. Ask what they understood and observed; do not collect a diary of private conversations.

Distribute a specific approved batch of tasks, not every tiny change. Preserve the exact tested candidate and build provenance. App Store/TestFlight review may be required; store upload does not equal public release. Test session revocation, account deletion and provider failure without using production personal records.

When a critical privacy defect is found, halt affected beta functionality/distribution where feasible, notify the owner, provide a safe workaround and issue a corrective build. Deleting a build from distribution does not remotely erase installed binaries or local history; communicate that limitation accurately.

20 Store submission and release assets

Asset	Required content and state
Name and availability	Eilo candidate; trademark/domain/store-name checks outstanding
Description	Free local-first AI conversation, optional local memory and confirmed online search
Privacy URL	Account/query/provider purposes, retention, deletion, local-history boundaries
Support URL	Contact route and safe issue-reporting instructions
Account deletion URL	Authenticated request/status route independent of installed app
Screenshots	Actual release UI on supported devices; no simulated capability claims
Icon and graphics	Licensed source files and platform exports
Age and content rating	Honest adult consumer positioning and safety review
Permission text	Clear microphone/background/notification/overlay purposes
Review notes	Model setup size, optional guest/auth flows and tested background use
Store declarations	Real data safety/privacy labels and required SDK/privacy manifests
License inventory	Exact model/runtime/voice/media redistribution rights

Proposed short description: “Talk naturally with Eilo. Conversation runs on your phone, with optional encrypted memory and visual replies. Confirm a query before checking online sources.” This is draft copy, not a claim that implementation already exists. Do not describe the whole app as entirely offline if optional search/auth/downloads are present.

Release checklist: owner accepts milestone evidence; store/privacy declarations match the build; dependency/signing provenance recorded; provider retention/cost limits approved; deletion/restore tested; all critical privacy/security failures closed; beta known issues disclosed; previous app/API compatibility retained; support/incident responsibility assigned; release candidate tested; separate backend/store/publication decisions recorded.

Use a staged public rollout when store mechanisms permit and monitor sanitized health data. Rollout pauses on critical privacy exposure, severe crash regression or core failure. Remediation is a compatible backend change or corrective binary; no remote feature switch can legitimately weaken approved privacy or turn on personal data collection.

21 Post launch observability

Conversation content is excluded from logs, analytics, session replay, crash breadcrumbs and support bundles. Initially use native/store operational diagnostics plus an explicit, optional sanitized diagnostic-sharing flow after provider review. Firebase Crashlytics or another SDK is not selected or automatically authorized by the checklist. Do not add stable advertising identifiers or infer mood/location profiles.

Signal	Collection rule	Response
Backend availability/error class	Aggregate counters without request bodies/credentials	Investigate service failure; guest core continues
Auth failures/rate anomalies	Minimum security metadata with documented expiry	Protect service; avoid enumeration leaks
Search spend/error rate	Aggregate request/cost totals, no query text or account IDs	Alert at approved thresholds; pause funded search if needed
Mobile crashes	Scrubbed reports only with reviewed collection basis	Reproduce on synthetic fixture and triage
Local latency/battery	Device-local metrics; optional synthetic test export	Adjust supported configuration only after review
Deletion queue	Protected status and minimal expiry-bound operation record	Retry/escalate, never show false completion

Provisional operational log retention is 7 days and deletion-record/security retention 30 days, subject to necessity and provider feasibility; these are assumptions, not current configuration. Backup/PITR horizons remain unresolved and must be finite before launch. Search payload logging is prohibited regardless of the metadata schedule.

The owner initially reviews operational health weekly during pilot and daily during the first rollout week as a planning assumption. There is no staffed 24-hour support commitment. Define incident acknowledgement and escalation expectations before inviting users. Severe issues may require immediate containment; statutory notices follow the actual applicable legal assessment.

Model updates use signed manifests, exact licenses, compatibility checks, staged verification and rollback. No automatic personal-model upload/training exists. Release a generic model only after the same quality/privacy/performance checks relevant to changed behavior. New online providers or telemetry fields require a recorded scope/data change.

22 Closeout and continuous improvement

Project closure sign off

Close an agreed release scope after owner acceptance, not merely after store upload. Record project/version, delivered requirements/tasks, accepted exceptions, test evidence, device support list, licenses/provider agreements, operational handover, budget actual/forecast and unresolved follow-up items. Owner signature/name, date and release decision remain blank until actual acceptance. A later milestone can close independently without claiming future training or app-control goals are complete.

Retrospective template

Review period; intended outcome; actual accepted delivery; defects or incidents; review bottlenecks; useful practices; one or two changes for the next cycle; action owner/date; confirmation at next review. Avoid blaming individuals or producing invented performance ratings. Separate product hypotheses that failed from execution errors.

Lessons learned register

Field	Meaning
Lesson ID/date	Stable record linked to evidence
Situation	Concrete build, device, provider or review issue
Observation	What actually happened, including uncertainty
Consequence	User/privacy/cost/schedule effect
Improvement	Specific change and accountable owner
Verification	Later evidence that the change helped

No lessons or retrospective outcomes are fabricated here. Seed topics for later review are iOS background viability, model quality versus size, locked-memory composition, search privacy, review size and GitHub visibility migration.

Archiving and version controls

Tag accepted release commits and document/model manifest revisions. Retain build provenance, task approvals, synthetic evidence, decisions and licenses; archive environment configuration without secrets. Keep active operational access restricted and revoke unused signing/provider credentials. Production personal data is never copied to an archive merely to document the project.

Prior prototypes/check reports remain explicitly versioned historical references. Design 2.0/tokens 2.0 and JSON1.5 control current visual scope. Document replacements preserve identity and revision history. Repository visibility migration cannot retract prior public copies; inspect history/licensing and controls before the change. Do not archive local private-session data or conversation history as project evidence.

23 Template coverage and deliverable status

This mapping covers every checklist item. Defined means documented here; it does not mean implemented, funded, legally cleared or verified.

Template item	Location	Current status
Business Case	1	Defined; demand/funding unvalidated
Project Charter	1	Proposed financial/resource assumptions
App Store Strategy Doc	3	Defined; store accounts/support list pending
Stakeholder Register	2	Roles mapped; specialists not engaged
Kickoff Meeting Agenda	2	Prepared; meeting not claimed
Product Requirement Doc	4 and updated MVP specification	Merged design scope
Agile Product Backlog and Epics	9 and JSON/MD/CSV	175 tasks,23 groups
UI UX Design System	5 and Design 2.0/tokens	Specified; native assets/Figma/device checks pending
Architecture and API Contracts	6 to 7 and architecture	Proposed contracts; OpenAPI implementation pending
Work Breakdown Structure	9 and task dependencies	Defined
Project Budget and Timeline	8 to 9	Assumptions, not authorized commitments
Risk and Communication Plans	10 to 11	Initial register and cadence
Sprint Planning Logs	12	Initial candidates/template; actual logs empty
Data Mapping Matrix	13	Defined; vendor implementation inventory pending
Consent and ATT Architecture	14 to 15	Defined; no tracking planned
Data Encryption Matrix	14	Targets; native/provider verification pending
CI CD Pipeline Layout	16	Defined; not configured
Change Request and Issue Logs	17	Current change and known gaps recorded
Timesheets and Resource Trackers	12	Template/capacity; actuals not invented
Sprint Metrics and Burndowns	18	Measurement definitions; no sprint data
Beta Distribution Tracker	19	Defined; no distribution occurred
Quality Metrics and Bug Log	18	Targets/log template; native evidence pending
Project Status Reports	11	Reporting format and initial limitations
App Store Submission Assets	20	Requirements/draft copy; assets pending
Post Launch Observability Plan	21	Defined; telemetry not deployed
Project Closure Sign off	22	Procedure; no release acceptance
Agile Retrospective Template	22	Prepared
Lessons Learned Register	22	Prepared; no invented outcomes
Archiving and Version Controls	22	Defined

24 Assumption register and next task

ID	Assumption	Review trigger
AS01	Owner is sponsor/product/project manager; one founder with agent support	Before staffing or delegation
AS02	Australia-first adult English pilot; no health-service positioning	Before store territory or partnership change
AS03	20 hours/week, 18 weeks, 360 hours	After first two weeks/native spikes
AS04	AUD80/hour economic value and AUD6,360 cash envelope	Before spending or budget baseline approval
AS05	Android15+, iOS18+, 8 GB initial test devices	Actual model/toolchain/device feasibility
AS06	Text on; images/video off; Voice only retains individual choices	First usability review
AS07	20-second visual idle; 10/20/60 options and session-only pin	Native accessibility/usability tests
AS08	Search off, per-query confirmation; no location permission	Provider/privacy review
AS09	256-character query and initially three visible items	Provider schema and usability tests
AS10	Explicit video playback pauses speech/listening; manual resume	Audio-route/native interaction tests
AS11	Generic-only outside-app iOS notification and all locked surfaces	Platform/device privacy review
AS12	Two-week cycles; five to ten study participants and 25-device beta	Capacity/recruitment authorization
AS13	AUD300/month operational review threshold	Actual usage/quotes and approved ceiling
AS14	7-day operational metadata and 30-day minimum deletion/security record expiry	Legal necessity/provider/restore review
AS15	EAS and Vercel recommended; GitHub Actions and Docker roles as specified	Native/auth build/hosting feasibility

These are planning values to review, not facts about current infrastructure or spending approvals. The 7-day active account deletion target is retained from the prior proposal; exact backup/vendor retention is still an open gate. No timeline, budget or mandatory tracking has been inferred from the attached checklist.

Immediate next task

Review this merged plan and assumptions, then authorize VC-DEVOPS-01 repository and board baseline. Confirm the GitHub owner/repository name and equipment access before executing dependent setup. Complete only that task, present evidence and pause for owner review. Continue existing native readiness/model/audio tasks only after their individual authorization. No project setup, code or deployment has been performed by this documentation task.

Main source documents

The supplied `mobile_app_project_checklist_v3.pdf` defines the five-phase checklist. Project source files are the updated MVP specification, architecture, implementation plan, design handoff/review, tokens 2.0, requirements/task JSON1.5 and CSV. The user's 5 October sketch informs spoken-answer/result presentation. Generated concept images and the one-second GIF are visual references, not real product screenshots or verification.

25 Official references

Platform and regulatory references support available mechanisms and assessment conditions, not measured Eilo performance or compliance clearance. Recheck current requirements before native implementation and submission.

- Apple ActivityKit and supported surfaces: <https://developer.apple.com/documentation/activitykit>
- Apple Live Activities: <https://developer.apple.com/documentation/activitykit/displaying-live-data-with-live-activities>
- Apple App Review Guidelines: <https://developer.apple.com/app-store/review/guidelines/>
- Apple tracking privacy: <https://developer.apple.com/app-store/user-privacy-and-data-use/>
- Android overlay permission: https://developer.android.com/reference/android/Manifest.permission#SYSTEM_ALERT_WINDOW
- Android overlay blocking: <https://developer.android.com/security/fraud-prevention/activities>
- Android microphone foreground service: <https://developer.android.com/develop/background-work/services/fgs/service-types#microphone>
- Expo EAS native builds: <https://docs.expo.dev/build/setup/>
- Expo existing native apps: <https://docs.expo.dev/bare/overview/>
- Expo store submission: <https://docs.expo.dev/deploy/submit-to-app-stores/>
- GitHub environment protection: <https://docs.github.com/en/actions/reference/workflows-and-actions/deployments-and-environments>
- Vercel Node runtime: <https://vercel.com/docs/functions/runtimes/node-js>
- Neon authentication overview: <https://neon.com/docs/auth/overview>
- Better Auth Expo integration: <https://www.better-auth.com/docs/integrations/expo>
- OAIC small business coverage: <https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/organisations/small-business>
- OAIC health-service coverage: <https://www.oaic.gov.au/privacy/your-privacy-rights/health-information/what-is-a-health-service-provider>
- HHS covered entities and business associates: <https://www.hhs.gov/hipaa/for-professionals/covered-entities/index.html>
- GDPR Article3 territorial scope: <https://eur-lex.europa.eu/eli/reg/2016/679/oj/eng>
- OWASP mobile storage controls: <https://mas.owasp.org/MASVS/05-MASVS-STORAGE/>
- W3C contrast benchmark: <https://www.w3.org/WAI/WCAG22/Understanding/contrast-minimum.html>